GUIA DE ENTREGA / OUTUBRO 2026

VI — Sunset Stories

Documentação técnica, funcionalidades e próximos passos



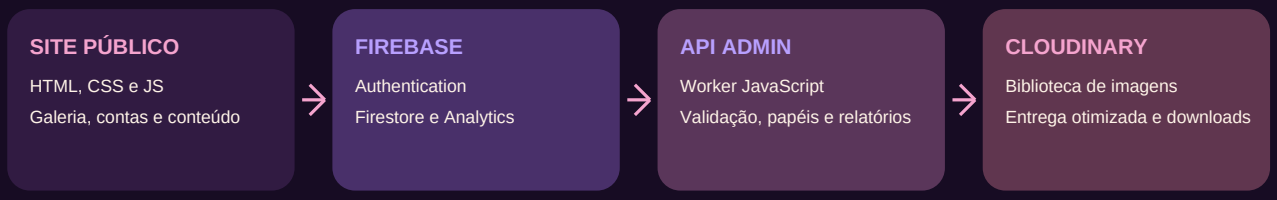
Uma experiência de fã independente com galeria para baixar, área de membros e painel administrativo. Este guia registra o que está publicado, como as peças se conectam e o que falta configurar para liberar todos os recursos.

VI / SUNSET STORIES

SITE vi-sunset-stories.epiccow8.chatgpt.site
API sunsetvi-image-api.epiccow8.chatgpt.site

01 / Visão geral

O produto combina uma página pública imersiva com uma área de conta e um painel restrito. O conteúdo principal está no site estático. Firebase cuida de autenticação e dados de usuário; uma API separada protege operações administrativas e faz a ponte com Cloudinary e GA4.



O navegador nunca recebe o segredo da Cloudinary nem a chave privada da conta de serviço.

Estado desta entrega

Área	Estado atual	Observação
Site público	PUBLICADO	Versão 33; HTTPS; home, galeria, trailer, FAQs e páginas legais.
Autenticação	ATIVA	Cadastro, login, recuperação e preferências via Firebase.
Galeria administrativa	ATIVA	Prévia de imagem, inclusão de cena, upload e edição; requer papel adequado.
Gestão de membros	AGUARDA CONFIGURAÇÃO	A API está publicada, mas precisa da conta de serviço Firebase.
Relatórios GA4 no admin	AGUARDA CONFIGURAÇÃO	Falta o ID numérico da propriedade e acesso da conta de serviço.
Backups e alertas	PENDENTE NO CONSOLE	São configurações operacionais fora do código do site.

Publicado: Site v33 e API v4. A documentação descreve o código e os ambientes verificados em 14/10/2026.

02 / Stack e responsabilidades

Componente	Tecnologia	Responsabilidade
Interface pública	HTML, CSS e JavaScript	Páginas, navegação, animações leves, galeria, busca/filtros, download e diálogos.
Identidade	Firebase Authentication	Cadastro, login, confirmação de e-mail, recuperação de senha e sessão. Senhas não são gravadas pelo site em Firestore.
Dados	Cloud Firestore	Perfil, preferências, favoritos, conteúdo editável, papéis administrativos e trilha de atividade.
API administrativa	Worker JavaScript (ESM)	Verifica token Firebase, papel, origem e corpo; executa rotas privilegiadas; não depende de sessão por cookie.
Mídia	Cloudinary	Armazena e entrega imagens. O backend aplica transformações automáticas e uma largura máxima para a galeria.
Medição	Firebase Analytics / GA4	Medição de uso com consentimento no site; relatórios internos usam a Google Analytics Data API quando configurada.
Hospedagem	Sites	Publicação HTTPS do site e da API, versões numeradas e variáveis de ambiente/segredos.

O que significa cada camada

- **Site:** pode ser lido por qualquer visitante. A chave de configuração Firebase visível no navegador é identificador público do projeto, não uma senha administrativa.
- **Firebase:** autentica usuários e aplica regras de acesso a dados quando o navegador usa o SDK cliente.
- **API:** valida novamente a identidade e o papel antes de operações sensíveis. Segredos ficam em variáveis protegidas no ambiente da API.
- **Cloudinary:** recebe arquivos por meio da API; a chave secreta nunca deve ser adicionada a HTML ou JavaScript do navegador.

A conta de serviço e a Analytics Data API ainda não estão configuradas no ambiente da API. Por isso, lista/gestão de contas e relatórios do GA4 não podem ser considerados prontos para uso.

03 / Mapa do site e experiência

Endereços publicados

Tela ou seção	Link direto	Status
Início	https://vi-sunset-stories.epiccow8.chatgpt.site/	Publicado
Galeria	https://vi-sunset-stories.epiccow8.chatgpt.site/#galeria	Publicado; imagens com opção BAIXAR
FAQ	https://vi-sunset-stories.epiccow8.chatgpt.site/#faq	Publicado; 5 perguntas
Entrar	https://vi-sunset-stories.epiccow8.chatgpt.site/#login	Publicado; abre diálogo de conta
Criar conta	https://vi-sunset-stories.epiccow8.chatgpt.site/#cadastro	Publicado; confirmação de e-mail depende do Firebase
Recuperar senha	https://vi-sunset-stories.epiccow8.chatgpt.site/#recuperar	Publicado; fluxo de recuperação Firebase
Erro 404	https://vi-sunset-stories.epiccow8.chatgpt.site/404.html	Página personalizada
Obrigado	https://vi-sunset-stories.epiccow8.chatgpt.site/obrigado.html	Página personalizada
Privacidade	https://vi-sunset-stories.epiccow8.chatgpt.site/privacidade.html	Página legal personalizada
Termos	https://vi-sunset-stories.epiccow8.chatgpt.site/termos.html	Página legal personalizada
Admin	https://vi-sunset-stories.epiccow8.chatgpt.site/admin/	Protegido por login e papel

Como o visitante usa

- Navega pela história, personagens e trailer oficial incorporado com modo de privacidade aprimorada.
- Filtra imagens por coleções, pesquisa/abre cenas e baixa o arquivo da imagem pelo cartão ou visualizador. O material baixado é imagem da galeria; o jogo não é distribuído.
- Cria uma conta para salvar favoritos e preferências. A interface oferece configurações de contraste, texto e movimento.
- No celular, os cartões se ajustam à largura da tela e há chamada de ação persistente.

As páginas 404, obrigado, privacidade e termos são páginas do site, não telas do Firebase. A confirmação e recuperação por e-mail também dependem dos modelos, domínios autorizados e limites do Firebase.

04 / Painel administrativo

O painel em /admin/ é separado da navegação pública. Ele busca conteúdo no Firestore e chama a API para ações que exigem privilégios de servidor.

Função	Permissão	Estado
Prévia e edição de cenas	Owner / editor	Disponível; prévia integral e seleção de imagem.
Adicionar nova cena	Owner / editor	Disponível; preencher título, texto alternativo e imagem antes de salvar.
Publicar/editar conteúdo	Owner / editor	Disponível para seções compatíveis.
Ver conteúdo em rascunho	Owner / editor / viewer	Permitido conforme regras e tela do painel.
Listar, convidar, bloquear e excluir contas	Owner	Implementado na API; aguarda FIREBASE_SERVICE_ACCOUNT_JSON.
Atribuir papéis	Owner	Papéis: owner, editor, viewer e sem acesso. Não conceda owner por teste.
Relatórios de uso GA4	Owner	Interface/API disponíveis; aguarda GA4_PROPERTY_ID, acesso e API habilitada.
Auditoria de ações	Admin	siteActivity é append-only; ações de edição ficam registradas.

Fluxo recomendado para publicar uma cena

1. Entrar com uma conta ativa de owner ou editor. 2. Abrir a galeria no admin. 3. Adicionar cena. 4. Informar título, categoria, descrição alternativa e estado de publicação. 5. Escolher JPG, PNG, WebP ou AVIF de até 8 MB. 6. Conferir a prévia e salvar. 7. Conferir a cena publicada no site e testar o download.

Se o upload falhar, confira a mensagem na tela, conexão com a API e variáveis CLOUDINARY_* no ambiente do backend. Não cole chaves secretas em chats, repositório ou campos de URL da imagem.

05 / Dados, papéis e permissões

Principais coleções do Firestore

Coleção	Uso	Controles principais
admins/{uid}	Papel e estado do acesso administrativo.	Cliente só pode ler o próprio documento; criação/alteração/remoção bloqueadas para cliente. Concessão via Console ou Admin SDK.
siteContent/{section}	Galeria, conteúdo e configurações publicáveis.	Público pode ler conteúdo publicado; admin também pode ler rascunho; owner/editor edita.
siteActivity/{id}	Trilha de ações administrativas.	Leitura para admin; criação com chaves e tamanhos validados; sem alteração ou remoção.
users/{uid}	Perfil, favoritos e preferências.	Cada pessoa acessa o próprio perfil; campos permitidos, favoritos limitados a 12, nome a 24 caracteres.

Matriz resumida

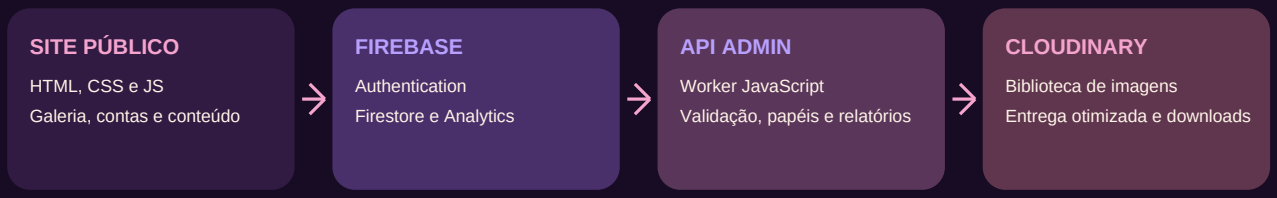
Ação	Visitante	Viewer	Editor	Owner
Ver site publicado	Sim	Sim	Sim	Sim
Ver rascunhos no admin	Não	Sim	Sim	Sim
Editar/publ. conteúdo e enviar imagens	Não	Não	Sim	Sim
Gerenciar membros e relatórios GA4	Não	Não	Não	Sim
Conceder papel a si próprio no cliente	Não	Não	Não	Não

Regra importante

O Admin SDK e chamadas de servidor autenticadas por conta de serviço ignoram as Firestore Security Rules e usam IAM. Por isso, a API valida token Firebase e papel antes de cada rota privilegiada. Mantenha a chave de serviço no segredo da API, conceda apenas os papéis necessários e revise operações de exclusão antes de executá-las.

06 / Imagens, armazenamento e downloads

Fluxo de envio



O navegador nunca recebe o segredo da Cloudinary nem a chave privada da conta de serviço.

No envio administrativo, o navegador manda a imagem e o token Firebase à API. A API confere origem, autenticação, papel, tamanho, tipo MIME e assinatura real do arquivo; em seguida assina a solicitação no servidor e envia para a pasta sunsetVI/gallery do Cloudinary. A resposta inclui URL de imagem otimizada e miniatura.

Limites e comportamento

- Tamanho máximo: 8 MB; tipos aceitos: JPEG, PNG, WebP e AVIF. A API verifica os bytes iniciais do arquivo, além do tipo informado pelo navegador.
- Limite atual: 10 uploads por usuário por minuto em memória do processo ativo. É proteção básica; não é limite global distribuído entre instâncias.
- A galeria usa URLs HTTPS e transformação automática de formato/qualidade, com largura máxima de 1800 px. Cartões usam miniaturas WebP geradas no site.
- O botão BAIXAR aparece na galeria e no visualizador. O visitante baixa a imagem apresentada, não arquivos executáveis nem conteúdo do jogo.

Cloudinary e Firebase Storage

O armazenamento ativo da galeria está encaminhado ao Cloudinary. Há regras de Firebase Storage no repositório como configuração de referência, mas esse não é o caminho de upload usado pelo painel atual. Faça backup da configuração e confirme quotas/retensão no provedor Cloudinary separadamente: backup do Firestore não cobre arquivos de mídia.

07 / Desempenho, acessibilidade e SEO

Tema	Implementado	Ponto de verificação
Carregamento	Hero priorizado/preload; imagens abaixo da dobra lazy; WebP; preconnect para fontes e Firebase.	Revisar Core Web Vitals depois de tráfego real e novos uploads.
Animação	Transições em CSS/JavaScript; controle para reduzir movimento e preferência do sistema. Lenis foi removido.	Evitar adicionar biblioteca pesada sem benefício mensurável.
Responsividade	Cards, formulários e navegação adaptados a telas menores. CTA persistente no mobile.	Testar novamente em iOS/Android e zoom 200%.
Acessibilidade	Texto alternativo, navegação por teclado, skip link, foco visível, labels e opção de movimento.	Auditar contraste e leitura de cada nova imagem/diálogo.
SEO técnico	Título e descrição únicos nas páginas HTML, canonical na home, Open Graph/Twitter, favicon, sitemap e robots.txt.	Páginas internas futuras também precisam title/description próprias.
Dados estruturados/local	Não aplicado.	Site de fã sem negócio físico; mapa, rota e schema de negócio local não são pertinentes.
Depoimentos	Não aplicado.	Não inventar avaliações: produto de fã não tem clientes.

Arquivos publicados

robots.txt e sitemap.xml estão em /robots.txt e /sitemap.xml. O arquivo principal tem CSP declarada no HTML; a API envia HSTS, nosniff, frame-ancestors, Referrer-Policy e Permissions-Policy. A hospedagem fornece HTTPS e a API redireciona solicitações HTTP para HTTPS.

Acessibilidade é uma prática contínua: ao substituir uma imagem, escreva um alt curto que descreva o que aparece. Para imagens decorativas, use alt vazio. Evite movimento automático intenso e mantenha o botão para reduzir animações.

08 / Segurança: status por requisito

Requisito	Estado	Como está tratado / o que falta
Forçar HTTPS	FEITO	Hospedagem HTTPS; API redireciona HTTP e envia HSTS.
CORS correto	FEITO	API permite somente a origem HTTPS do site; resposta varia por Origin.
Hash de senhas	DELEGADO AO FIREBASE	Site não armazena senha; Firebase Authentication administra credenciais.
Cookies/sessão	SEM COOKIE PRÓPRIO	Autenticação envia token Firebase Bearer; persistência gerida pelo SDK Firebase.
Segredos fora do código	FEITO COM REVISÃO	Segredo Cloudinary e chaves de servidor em variáveis secretas. Rotacione a chave que foi compartilhada durante a configuração e atualize o segredo no backend.
Permissões por recurso	FEITO	Regras Firestore e checagens de papel em rotas da API; teste ao mudar regras.
Expiração/invalidação	PARCIAL	Tokens Firebase expiram/renovam pelo SDK; desligar conta impede login novo. Revise revogação e sessões ativas em caso de incidente.
RLS	N/A / EQUIVALENTE	Não há SQL/Postgres. Firestore Security Rules controlam acesso a documentos.
Rate limiting	PARCIAL	Upload tem limite em memória por usuário; operações admin não têm rate limit distribuído. Avaliar gateway se abuso/volume justificarem.
Validação de entrada	FEITO	API limita tamanho, campos permitidos, UID, e-mail, papel e imagem. Regras Firestore validam esquema do perfil.
SQL injection	N/A	Não existe banco SQL nesta arquitetura.
XSS	MITIGADO	Conteúdo administrativo aparece como texto; CSP restringe origens. Rever qualquer novo HTML dinâmico.
CSRF	MITIGADO / NÃO USADO	Sem autenticação por cookie; Bearer token, origem exata e preflight CORS.
Cabeçalhos de segurança	FEITO	CSP do site e cabeçalhos na API; revisar CSP ao integrar novos fornecedores.
Tipo/tamanho de upload	FEITO	8 MB e quatro formatos; validação de assinatura real no servidor.
Erros sem detalhes internos	FEITO	Mensagens genéricas para o usuário; causas internas não devem ser exibidas.
Criptografia	DELEGAÇÃO AO PROVEDOR	HTTPS em trânsito. Proteção em repouso depende dos serviços gerenciados; não há criptografia adicional ponta a ponta do conteúdo.
Dependências	MANUAL	Atualizações não são automáticas; revisar SDK Firebase e dependências antes de publicar.
Backups automáticos	PENDENTE	Agendar backup do Firestore; mídia Cloudinary precisa política própria.
Monitoramento/alertas	PENDENTE	Criar alertas no Cloud Monitoring e acompanhar Authentication, API e GA4.

09 / Tutorial: liberar membros e relatórios

A API está no ar, mas a tela de gestão de membros e os relatórios precisam de duas variáveis que você configurará depois. Trabalhe somente no projeto Firebase/Google Cloud sunsetvi.

A. Criar a conta de serviço Firebase

- Abra Google Cloud Console e selecione o projeto sunsetvi. Entre em IAM e administrador > Contas de serviço > Criar conta de serviço. Use um nome descritivo, por exemplo sunsetvi-admin-api.
- Conceda somente os papéis necessários para as rotas do backend: Firebase Authentication Admin e Cloud Datastore User. Não conceda Owner/Editor do projeto. Confirme no IAM que a conta pertence ao projeto correto.
- Crie uma chave JSON se o ambiente da API aceitar somente esse formato. Baixe-a localmente e guarde-a em cofre de senhas. Não mande o JSON por chat, e-mail ou commit. A chave privada é uma credencial de alto impacto.
- No ambiente/segredos do serviço SunsetVI Admin & Media API, crie FIREBASE_SERVICE_ACCOUNT_JSON como segredo e cole o JSON integral. Salve e publique uma nova versão da API. Apague cópias temporárias de locais compartilhados.
- Teste /admin/: como owner, confira lista de membros; crie convite de teste; bloqueie/reative uma conta de teste; confirme que viewer/editor recebem acesso negado às ações de owner.

B. Conectar GA4 à API

- Ative Google Analytics Data API no projeto Google Cloud sunsetvi (APIs e serviços > Biblioteca > Google Analytics Data API > Ativar).
- No Google Analytics, abra Administrador > Gerenciamento de acesso à propriedade e adicione o e-mail da conta de serviço como Leitor.
- Copie o ID numérico da propriedade GA4 e configure GA4_PROPERTY_ID no serviço API. Não use o ID de medição que começa por G-.
- Publique a API novamente. No painel, peça relatórios de 7, 30 e 90 dias e confirme usuários ativos, sessões, visualizações, páginas e origens.

Segredo: se uma chave já foi exposta em mensagem ou arquivo, rotacione-a no Cloudinary Console e substitua o segredo do backend. Depois valide upload e exclua a chave antiga. Faça a rotação com atenção para não deixar o serviço usando credencial revogada.

10 / Tutorial: backups, alertas e operação

Backups do Firestore

- No Firebase Console, abra sunsetvi > Firestore Database > Backups. Escolha uma programação diária ou semanal e uma retenção compatível com o que você precisa recuperar.
- Confira custos e requisitos do plano antes de ativar: backups e armazenamento podem gerar cobrança. Backup do Firestore não inclui imagens guardadas no Cloudinary.
- Documente quem pode restaurar, onde restaurar e como validar os dados. Faça um teste de restauração em banco separado antes de depender do processo em incidente.

Monitoramento e alertas

- No Google Cloud Console, abra Monitoring > Alerting e crie um canal de notificação para o e-mail que acompanha o projeto.
- Comece com alerta para erros/indisponibilidade da API e falhas de autenticação que excedam o padrão normal. Se o serviço não expõe métricas suficientes, acompanhe logs e configure alertas baseados em logs.
- No Firebase Console, revise Authentication > Usuários e os indicadores de uso. No GA4, observe tráfego anormal e falhas de páginas. Não coloque tokens, e-mails completos ou segredos em logs de alerta.
- Crie um orçamento no Google Cloud Billing para receber avisos de gasto. Aviso de orçamento ajuda a monitorar, mas não é um teto automático de consumo.

Revisão mensal recomendada

- Conferir administradores ativos e remover papéis que não são mais necessários.
- Verificar cópia de segurança e registrar data do último teste de restauração.
- Revisar versões/alertas de dependências e atualizar com teste antes de publicar.
- Confirmar que nenhuma variável secreta foi copiada para o código-fonte ou logs.

Conta de serviço: trate como senha-mestra. Nunca publique arquivo JSON em repositório; use segredo do serviço e restrinja quem pode visualizar ou editar variáveis protegidas.

11 / Roteiro de validação

Teste	Passos	Resultado esperado
Cadastro	Criar usuário de teste, confirmar e-mail, sair e entrar.	Conta criada; e-mail confirmado; login funciona; nenhum texto técnico exposto.
Recuperação	Solicitar redefinição para conta existente e inexistente.	Resposta neutra; e-mail chega para conta existente; link leva ao domínio autorizado.
Permissões	Testar owner, editor e viewer em /admin/.	Viewer lê rascunhos; editor edita conteúdo; somente owner gerencia contas/relatórios.
Nova cena	Criar cena de teste com imagem válida, alt e título.	Prévia aparece completa; upload salva; cena aparece uma vez no site e baixa corretamente.
Upload inválido	Enviar arquivo >8 MB, extensão aceita com conteúdo inválido e tipo não permitido.	API recusa cada caso sem expor detalhes internos.
CORS	Chamar API a partir de origem diferente.	Resposta não libera leitura cross-origin.
Regras Firestore	Tentar ler perfil alheio e promover usuário pelo navegador.	Acesso negado; cliente não altera documento admins.
404 e SEO	Abrir /404.html, páginas legais e conferir título/descrição.	Página customizada; título/metadados próprios; links de retorno funcionam.
Mobile/acessibilidade	Usar 360px de largura, teclado, zoom e reduzir movimento.	Sem sobreposição; foco visível; controles alcançáveis; movimento reduzido.
Backup/alerta	Ver última execução de backup e disparar teste de notificação quando disponível.	Restauração de teste e notificação chegam à pessoa responsável.

Verificações já executadas na entrega

- Checagem de sintaxe JavaScript para os arquivos principais do site e Worker da API.
- Build e validação do artefato da API.
- Testes simulados da API para CORS, recusa de origem desconhecida, assinatura de imagem válida/inválida, autenticação, fluxo de upload e cabeçalhos.
- Conferência de referências HTML, FAQ, robots/sitemap e tamanhos gzip de CSS/JS. As saídas comprimidas principais ficaram perto de 10 KB cada.

Esses testes não substituem teste real com credenciais de produção, teste de restauração ou varredura de segurança externa. Faça a validação manual acima depois de concluir as configurações pendentes.

12 / O que falta implementar ou configurar

Prioridade	Item	Próxima ação / critério de pronto
Alta	FIREBASE_SERVICE_ACCOUNT_JSON	Criar conta de serviço mínima, guardar JSON como segredo e testar gestão de membros como owner.
Alta	GA4_PROPERTY_ID + API	Habilitar Data API, dar acesso Leitor à conta de serviço e testar relatórios 7/30/90 dias.
Alta	Rotação do segredo Cloudinary	Como a chave foi compartilhada na conversa de configuração, gerar nova chave/segredo e atualizar segredo do backend; validar upload com nova credencial.
Média	Backup automático Firestore	Configurar agenda, retenção e testar restauração em banco separado; confirmar cobrança/limites.
Média	Alertas operacionais	Configurar notificação, política para erros/indisponibilidade e orçamento; testar recebimento.
Média	Rate limit distribuído	O limite atual é por processo Worker e só para upload. Reavaliar se houver abuso/volume; preferir recurso de borda/provedor com armazenamento compartilhado.
Média	Privacidade Analytics	Manter consentimento claro e verificar configuração/região/retensão do GA4 conforme público e política publicada.
Baixa	Auditoria recorrente	Rever dependências, papéis, CSP, regras e backups mensalmente.
Feito	Core do site, galeria, download, auth e SEO técnico	Publicado; manter teste de regressão ao editar.

Critério de conclusão

A entrega operacional fica completa quando membros e analytics passarem nos testes como owner, backups tiverem uma restauração de ensaio, alertas chegarem ao contato responsável e o segredo Cloudinary rotacionado estiver validado. Registre a data e a pessoa que fez cada etapa.

Não é necessário adicionar mapa, endereço, marcação de negócio local ou avaliações de clientes a este site: não há local físico nem clientes que deem depoimentos. Isso evita sinalizar dados falsos aos buscadores ou visitantes.

13 / Fontes oficiais e links úteis

Os passos de configuração foram baseados nas documentações oficiais dos provedores. Os consoles mudam de rótulo ao longo do tempo; procure o nome do serviço indicado caso o menu tenha mudado.

Firebase Authentication: documentação
https://firebase.google.com/docs/auth/

Firebase Auth: persistência de sessão na Web
https://firebase.google.com/docs/auth/web/auth-state-persistence?hl=pt-br

Firestore: regras de segurança e condições
https://firebase.google.com/docs/firestore/security/rules-conditions?hl=pt-BR

Firestore: backups e restauração
https://firebase.google.com/docs/firestore/backups?hl=pt-br

Google Cloud: criar conta de serviço
https://cloud.google.com/iam/docs/service-accounts-create

Google Cloud: práticas recomendadas para contas de serviço
https://cloud.google.com/iam/docs/best-practices-service-accounts

Google Cloud: criar e excluir chaves de conta de serviço
https://cloud.google.com/iam/docs/keys-create-delete

Google Analytics: gerenciar acesso à propriedade
https://support.google.com/analytics/answer/9305587?hl=pt-BR

GA4 Data API: ID numérico da propriedade
https://developers.google.com/analytics/devguides/reporting/data/v1/property-id

GA4 Data API: início rápido e ativação
https://developers.google.com/analytics/devguides/reporting/data/v1/quickstart

Google Cloud Monitoring: criar alertas no Console
https://docs.cloud.google.com/monitoring/alerts/using-alerting-ui

Cloudinary: assinaturas de autenticação
https://cloudinary.com/documentation/authentication_signatures

Cloudinary: rotação de chave no Console
https://cloudinary.com/documentation/ts_how_to_rotate_api_keys_in_the_console

Cloudinary: envio programático de imagens
https://cloudinary.com/documentation/upload_images

Documento de referência do projeto. Não inclua credenciais no PDF nem compartilhe arquivos JSON de conta de serviço. Em caso de mudança nas regras do Firebase ou no runtime do Sites, atualize os passos antes de seguir o tutorial.